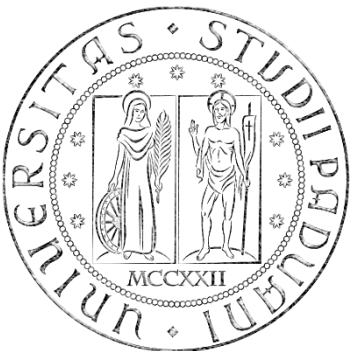


Biomedical Wearable Technologies
for Healthcare and Wellbeing

Regulation on data protection and AI

A.Y. 2025-2026
Giacomo Cappon



Privacy

- **Privacy:** the right to a private life, to be autonomous, in control of information about yourself, to be let alone.
- Almost every country in the world recognises privacy in some way.
- Privacy recognised as a universal human right.
 - Universal Declaration of Human Rights (Article 12)
 - European Convention of Human Rights (Article 8)
 - European Charter of Fundamental Rights (Article 7).



Data protection

- The European Charter of Fundamental Rights (Article 8) contains an explicit right to the **protection of personal data**.
- **Data protection** → ensure the fair processing (collection, use, storage) of personal data by public and private sectors.
- **Personal data:** any information related to an identified or identifiable natural (living) person
 - Identifiable natural person: one who can be identified, directly or indirectly, by an identifier such as a name, an identification number, location data, etc.
- Examples of personal data:
 - Names, dates of birth, photographs, email addresses and telephone numbers
 - IP addresses and communication content related to or provided by end-users of communications services

General Data Protection Regulation (GDPR)

- New regulation for data protection adopted by the EU in 2016.
- GDPR is the most comprehensive and progressive data protection regulation worldwide.
- Each EU member state adopted a national regulation on data protection that is compliant with the GDPR.
 - Italian law: **DECRETO LEGISLATIVO 10 agosto 2018, n. 101**. Disposizioni per l'adeguamento della normativa nazionale alle disposizioni del regolamento (UE) 2016/679 del Parlamento europeo e del Consiglio, del 27 aprile 2016, relativo alla protezione delle persone fisiche con riguardo al trattamento dei dati personali, nonché alla libera circolazione di tali dati e che abroga la direttiva 95/46/CE (regolamento generale sulla protezione dei dati).
- The GDPR also applies to entities not established in the EU who offer goods and services to individuals in the EU or monitor their behaviour.



Living and dead individuals

- The GDPR only applies to the personal data related to an **identifiable living individual**.
- Information relating to a dead person is not subject to the GDPR.
- Single member states are allowed to define their own rules for the protection of dead people.
- Italy has extended the application of the GDPR to dead people with the regulation Decreto Legislativo 101/2018.



Pseudonymised and anonymised data

- **Pseudonymisation:** a technique that replaces or removes information that identifies an individual.
- GDPR definition: “...*the processing of personal data in such a manner that the personal data can no longer be attributed to a specific data subject without the use of additional information, provided that such additional information is kept separately and is subject to technical and organisational measures to ensure that the personal data are not attributed to an identified or identifiable natural person.*”
- Example of pseudonymisation: replacing names and other identifying attributes with a unique identifier.
 - The data controller can still match the unique identifier to the individual having access to relevant additional information.
 - Technical measures must be used to ensure that this additional information is held separately and no one apart the authorized people can retrieve it.
- Pseudonymisation help protecting the privacy of subjects' identity.
- **Remember:** Pseudonymised data are still personal data → subject to GDPR.

Pseudonymised and anonymised data

- **Anonymisation:** a technique that eliminates all the information that identifies an individual.
- “...***The principles of data protection should therefore not apply to anonymous information, namely information which does not relate to an identified or identifiable natural person or to personal data rendered anonymous in such a manner that the data subject is not or no longer identifiable.*** This Regulation does not therefore concern the processing of such anonymous information, including for statistical or research purposes.”
- If at any point we realise that some information allows to re-identify individuals, data should be considered as pseudonymised.
- **Remember:** The GDPR does not apply to personal data that has been anonymised.

The "actors"

- **Data subject:** the person whose personal data are collected, held or processed.
- **Data controller:** the natural or legal person, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data.
 - It is the official responsible for data protection.
 - The actual processing may be delegated to another party, called the data processor.
- **Data processor:** a natural or legal person, public authority, agency or other body which processes personal data on behalf of the controller.
 - The processor only acts "on behalf of the controller" subject to his instructions.
 - The processor may have recourse to a **subcontractor** who processes the data on his behalf.
- **Recipient:** a natural or legal person, public authority, agency or another body, to which the personal data are disclosed.
- **Data protection officer (DPO):** expert in data protection regulation and practices. Guarantees that the GDPR directives are followed and acts as a point of contact with the Data Protection Authorities.



Data Protection Authorities

- National **Data Protection Authorities (DPAs)** or Regulators have been established to be the guardians of data protection.
 - The Italian one is: **Garante per la protezione dei dati personali** (<http://www.garanteprivacy.it/>)
- DPAs have the power to investigate, detect and punish violations of data protection rights and obligations.
- In the EU, DPAs must be **independent of any political, governmental or other influence**.
- **European Data Protection Supervisor (EDPS)**: independent supervisory authority responsible for ensuring that EU institutions and bodies comply with data protection law when processing personal data.



Restrictions to the application of GDPR

- In the EU, privacy and data protection are **not absolute rights** and can be limited under certain conditions according to the EU Charter of Fundamental Rights.
- Need to balance the rights to privacy against other EU values, human rights (e.g., right to freedom of expression), public and private interests (e.g., right to freedom of press), and national security.
 - GDPR not applicable if data are used for the purposes of prevention, investigation, detection or prosecution of criminal offences.
- DPAs ensure the balance between privacy and other interests.



GDPR: seven main principles

1. Lawfulness, fairness and transparency: Personal data shall be processed lawfully, fairly and in a transparent manner in relation to the data subject.

- Identify valid grounds under GDPR (known as a 'lawful basis') for collecting and using personal data.



2. Purpose limitation: Personal data shall be collected for specified, explicit and legitimate purposes and not further processed in a manner that is incompatible with those purposes.

- Purposes for processing must be clear from the start
- Further processing for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes are not considered to be incompatible with the initial purposes



GDPR: seven main principles

3. **Data minimisation:** Personal data shall be adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed.
4. **Accuracy:** personal data must be accurate and, where necessary, kept up to date.
 - Personal data that are inaccurate must be erased or rectified without delay.
5. **Storage limitation:** personal data shall be stored in a form which permits identification of data subjects for no longer than is necessary for the purposes for which they are processed.
 - Personal data may be stored for longer periods only if they are processed for archiving purposes in the public interest, scientific/historical research purposes or statistical purposes.



GDPR: seven main principles

6. Integrity and confidentiality: appropriate security of the personal data must be ensured using appropriate technical security measures.

- Protection against unauthorised or unlawful processing and against accidental loss, destruction or damage.



7. Accountability: The controller shall be responsible for, and be able to demonstrate compliance with the principles of the GDPR.



Data subjects rights under GDPR

- **The right to be informed**
 - Right to be informed about the collection and use of their personal data.
- **The right of access**
 - Right to access and receive a copy of their personal data, and other supplementary information, including the purpose and period of processing.
- **The right to rectification**
 - Right to have inaccurate personal data rectified or completed.
- **The right to erasure ('right to be forgotten')**
 - Right to have personal data erased.
- **The right to object**
 - Right to object to the processing of personal data in certain circumstances.



Data subjects rights under GDPR

➤ The right to restrict processing

- Right to request the restriction or suppression of their personal data. When processing is restricted, the controller can store the data, but not use it.

➤ The right to data portability

- Right to move, copy or transfer personal data easily to another controller.

➤ Rights not to be subject to **automated decision making and profiling**.

- Right not to be subject to a decision based solely on automated processing, including profiling, which significantly affects him or her.
- **Profiling:** use of personal data to evaluate or predict certain personal aspects relating to a person, e.g., performance at work, economic situation, health, personal preferences, interests, position...



Security measures

- Techniques for the **pseudonymisation** and **encryption** of personal data
- Techniques to ensure confidentiality, integrity, availability and resilience of processing systems and services
- Techniques to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident
- Techniques for regularly testing, assessing and evaluating the effectiveness of security measures



Lawful basis for data processing under GDPR

- The processing of personal data is lawful if at least one of the following applies:
 - **Consent:** the data subject has given clear consent for processing his or her personal data for a specific purpose.
 - **Contract:** the processing is necessary for a contract you have with the individual.
 - **Legal obligation:** the processing is necessary to comply with a legal obligation to which the controller is subject.
 - **Vital interests:** the processing is necessary to protect someone's life.
 - **Public task:** the processing is necessary for performing a task in the public interest.
 - **Legitimate interests:** the processing is necessary for your legitimate interests or the legitimate interests of a third party, unless there is a good reason to protect the individual's personal data which overrides those legitimate interests.
- Data controllers and processors are required to provide information about the lawful basis for processing usually through a privacy notice.



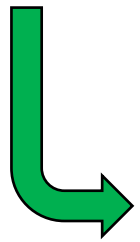
Consent

- Lawful basis based on consent → the controller shall be able to demonstrate that the data subject has consented to processing of his or her personal data.
- **Consent:** any freely given, specific, informed and unambiguous indication of the data subject's wishes by which he/she agrees to the processing of his/her personal data.
- The **request for consent** must be clear and presented using plain language.
- The data subject has the **right to withdraw** his or her consent at any time.
- Withdrawing the consent should be as easy as giving the consent.

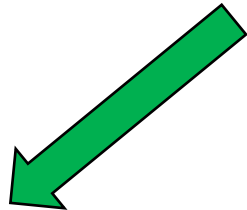


Example: Informed consent form for participating in a research trial

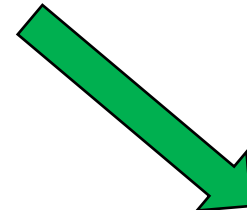
- Planning a research trial in which you collect some personal data.



- Each participant must provide an explicit consent by which they agree with you processing their data for the purpose of the research.



- **Information sheet:** document to share the information of the research trial.



- **Consent form:** form by which the subject provides the consent and agree to participate in the study.

Example of an information sheet template

INFORMATION SHEET FOR STUDY PARTICIPANTS

Study Title:

Sponsor's Protocol Code:

Sponsor:

Research Center:

Principal Investigator in the Center:

This information sheet is to inform you about a research study that we invite you to participate in. This study has been approved by the Ethics Committee <PLEASE INCLUDE REFERENCE AND DATE>. Before you decide whether you can take part, we would like to explain what is involved in this study and what your participation means. Please, take your time to read the information sheet and ask any questions that may arise.

Why are we doing this study?

< STUDY PURPOSES/FUTURE PURPOSES (if any)>

Why have I been asked to take part?

< ADD INCLUSION CRITERIA>

What will happen if I decide not to take part?

< EXPLAIN VOLUNTARY PARTICIPATION AND NO IMPACT ON DISEASE CARE>

What will we need to do if you take part?

< INCLUDE DETAILS ON DATA TO BE COLLECTED AND, THE STUDY PROCEDURES FOR THE COLLECTION>

What are the possible benefits and disadvantages of taking part?

< INCLUDE DETAILS ON THE BENEFITS AND RISKS, if any>.

More information about taking part

Subject Confidentiality

<INCLUDE COMPLIANCE WITH EXPLICIT DATA PROTECTION LAWS (GDRP)>.

< INCLUDE OTHER PEOPLE HAVING ACCESS TO DATA>

< INCLUDE DETAILS OF THE STORAGE PERIOD AND THE STORAGE LOCATION>.

< INCLUDE DETAILS ON THE FURTHER USE OF ANONYMIZED DATA AND SAMPLES AFTER THE END OF THE PROJECT, IF APPLICABLE>.

< INCLUDE DETAILS ON DATA AND SAMPLE TRANSFER AND THE SAFEGUARDES MEASURES ADOPTED, IF ANY>.

< DESCRIBE THE RIGHTS OF THE PARTICIPANT>

< INCLUDE NAME AND CONTACT DETAILS OF THE DATA CONTROLLER>.

< INCLUDE NAME AND CONTACT DETAILS OF THE DATA PROTECTION OFFICER, if applicable>

What will happen in case of incidental findings that might be relevant for study participants' health status?

< DESCRIBE WHAT WILL HAPPEN IN CASE OF INCIDENTAL FINDINGS>.

What will be done with the results?

<INCLUDE INFORMATION ABOUT THE PUBLICATION OF THE ANONYMIZED DATA AND THE RESULTS OF THE STUDY, IF APPLICABLE>.

Who is organizing this research?

<NAME OF THE SPONSOR>

Dr. _____ (center IP)

Hospital _____

Department of _____

Address _____

Example of a consent form template

CONSENT FOR STUDY PARTICIPANTS

Study Title:

Sponsor's Protocol Code:

Sponsor:

Research Center:

Code of Patient:

I, (name and surname)

PART I – CONSENT TO THE RESEARCH:

- ☐ have read and understood the information sheet (version ..., date....) provided relating the study <PLEASE INSERT STUDY TITLE> and have received a copy of this document.
- ☐ have been able to ask questions which have been answered fully.
- ☐ understand that my participation is voluntary and I am free to withdraw, without giving any reason and my care will not be affected in any way.
- ☐ have had enough time to fully consider my participation in the study.
- ☐ want to be informed of the overall study results at the end of the project.
- ☐ give permission to be informed of incidental findings that might be relevant for my health status.

PART II – CONSENT TO THE DATA PROCESSING:

- ☐ understand that my clinical information may be reviewed by properly authorized individuals as part of the study and that such information will be treated as strictly confidential.
- ☐ am aware of the type of data and samples that will be collected.
- ☐ give permission for using of the samples and data for the study purposes stated in the information sheet.
- ☐ am aware that the persons stated in the information sheet, bound by professional secrecy, will have the authority to access my study data and medical records.
- ☐ agree that anonymised study data will be communicated or published in specialized reports.
- ☐ give permission for storage of the study data and samples until <ENTER DATE>.
- ☐ am aware of the identity of the data controller and of the data protection officer.

- ☐ am aware of the transfer of data from <please include the provider country> to <please include the recipient country>.
- ☐ am aware that I have the right to request access to and rectification or erasure of my personal data or restriction of processing concerning personal data or to object to processing as well as the right to data portability.
- ☐ am aware that if I withdraw from the study, samples will be destroyed and data already collected will be anonymised and may be processed by authorised researchers.

I give consent to the participation in this research study

Name of Study Participant

Date

Signature

(Please write in capital letters)

I declare that I have fully informed above mentioned participant about this research study. If during the study new information becomes available that could influence the consent of the participant or can help to provide new treatment or healthcare, I will immediately inform them.

Name of Researcher

Date

Signature

(Please write in capital letters)

One copy to study participant, one to case notes, one to study file.

Example of an informed consent form for the use of cookies

YOUR LOGO

Powered by **Cookiebot**
by Usercentrics

Consent

Details

About

This website uses cookies

We use cookies to personalise content and ads, to provide social media features and to analyse our traffic. We also share information about your use of our site with our social media, advertising and analytics partners who may combine it with other information that you've provided to them or that they've collected from your use of their services.

Necessary

Preferences

Statistics

Marketing

☐

☒

☒

☒

Deny

Allow Selection

Allow all

Special categories of personal data (Art 9)

Personal data revealing:

- racial or ethnic origin
- political opinions
- religious or philosophical beliefs
- trade union membership
- data concerning physical or mental health
- data concerning sexual life or sexual orientation
- genetic data or biometric data (physical, physiological or behavioural characteristics which allow or confirm the unique identification of a person)

The processing of these kind of data **shall be prohibited**.

Conditions for use of special categories of personal data

Exceptions in which special personal data can be processed exist:

- the data subject gives explicit **consent** to the processing of those personal data;
- processing is necessary for carrying out the **obligations** and exercising specific rights of the controller or of the data subject;
- processing is necessary to protect the **vital interests** of the data subject or of another person and the data subject is physically or legally incapable of giving consent;
- processing is done within an organization for **legitimate purposes**, solely for members of the organization, and data are not disclosed outside the organization without the consent of the data subject;
- the personal data are manifestly made **public** by the data subject;
- ...

Conditions for use of special categories of personal data

- ...
- processing is necessary for the establishment, exercise or defence of **legal claims**;
- processing is necessary for reasons of **public interest**;
- processing is necessary for the purposes of preventive or occupational **medicine**, for the assessment of the working capacity of the employee, medical diagnosis, the provision of health or social care or treatment or the management of health or social care systems;
- processing is necessary for reasons of **public health**, such as protecting against serious cross-border threats to health;
- processing is necessary for archiving purposes in the public interest, **scientific** or historical research purposes or statistical purpose.

Records of processing activities

- Each **controller** shall maintain a **record of processing activities** under its responsibility (including name of the controller; purpose of processing; security measures adopted;...)
- Each **processor** shall maintain a **record of processing activities** carried out on behalf of the controller (including name the processor and of the controller; purpose of processing; security measures adopted;...)

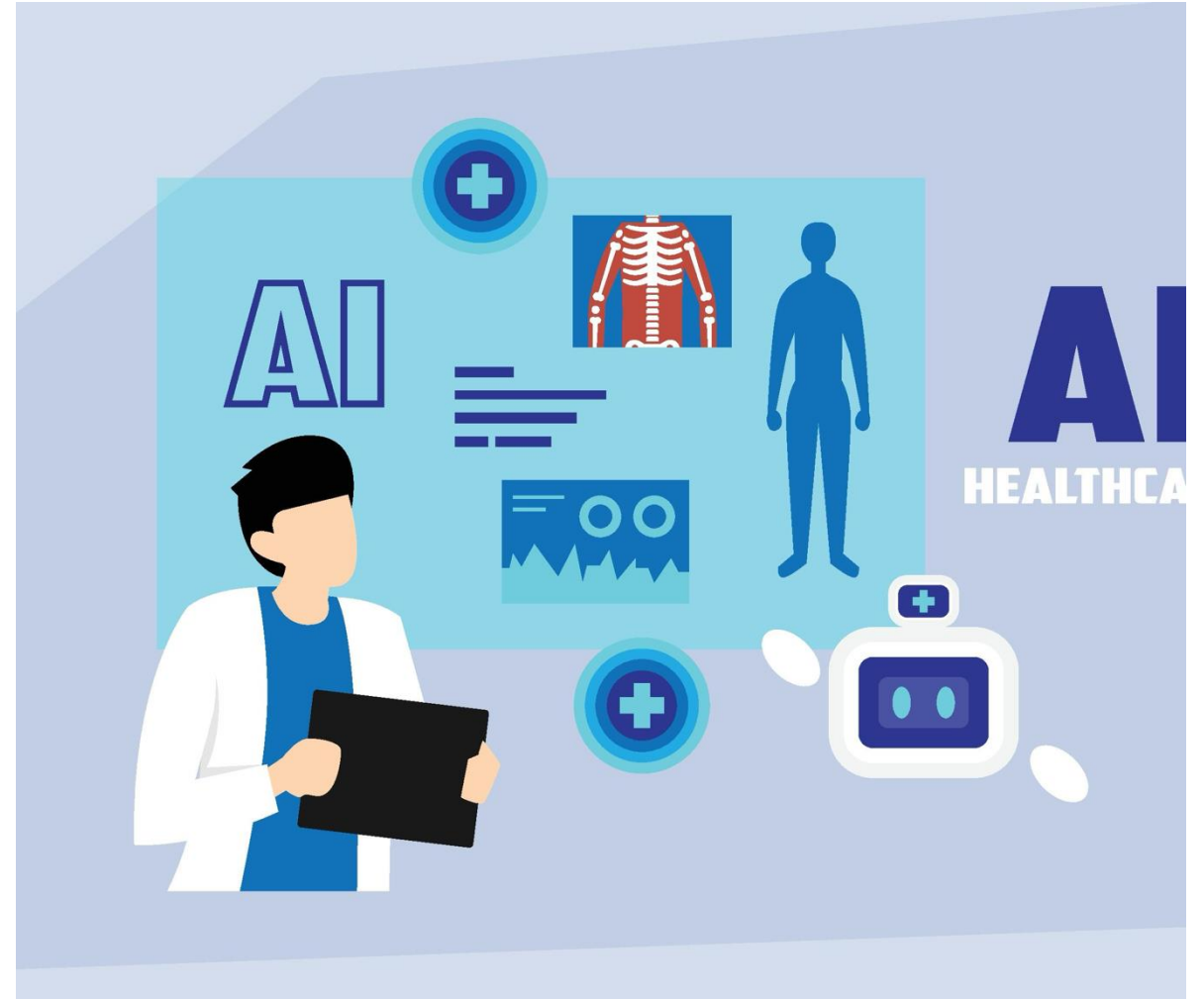


Secondary use of the personal data

- **Secondary use of the personal data:** the controller intends to further process the personal data for a purpose other than that for which the personal data were collected
- Prior to that further processing, the controller shall provide the data subject with **information on that other purpose** and any relevant further information.

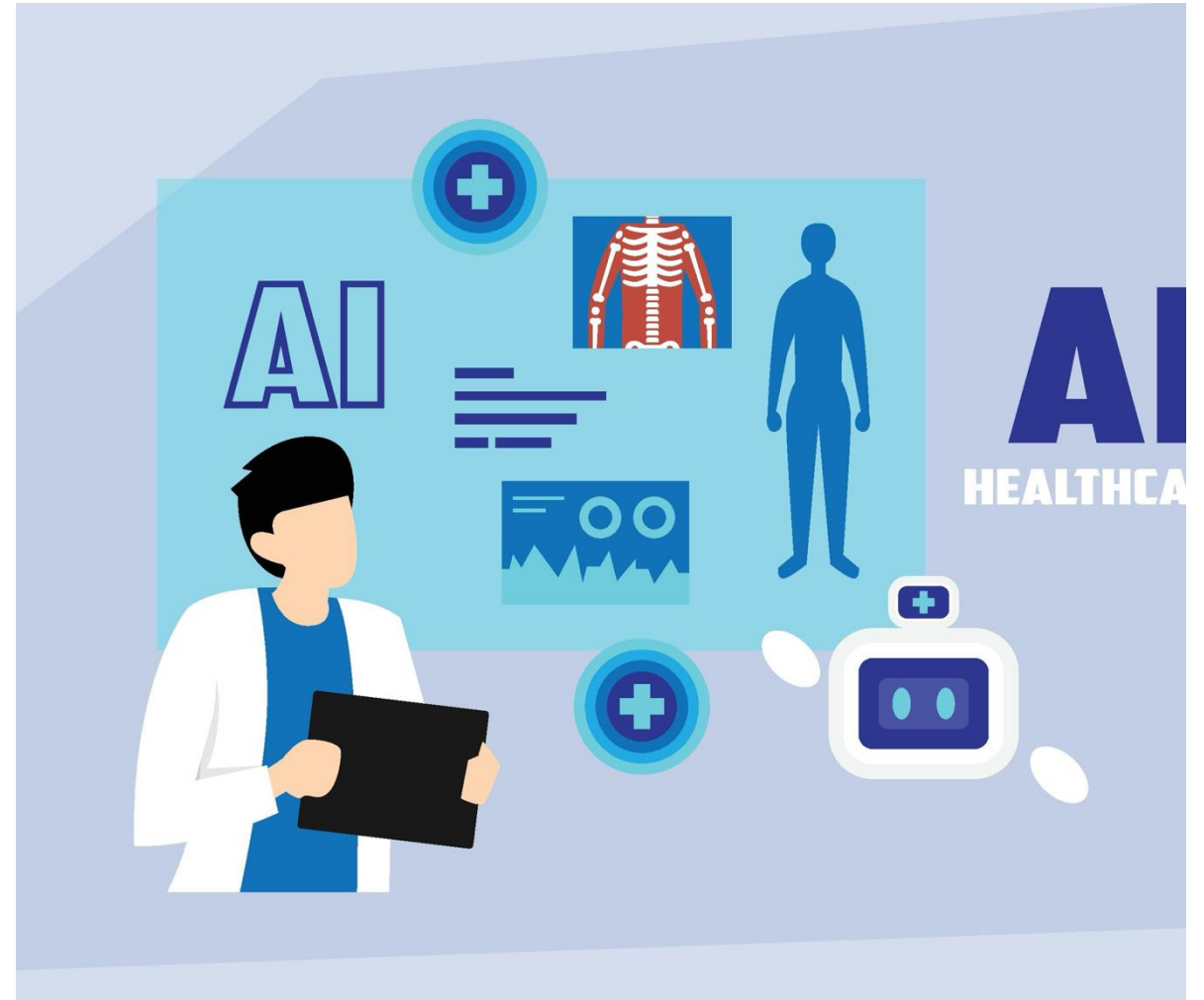
What about AI?

- **Should AI be regulated following the same principles?**



What about AI?

- **Artificial Intelligence systems are increasingly used in:**
 - Healthcare (diagnosis, risk prediction)
 - Recruitment and education
 - Credit scoring
 - Law enforcement
 - Autonomous vehicles
 - Social media recommendation systems
- **These systems can:**
 - Make mistakes
 - Discriminate
 - Violate fundamental rights
 - Be opaque (“black boxes”)
- **The EU decided to regulate AI specifically.**



The AI-Act

- The **AI-Act** → The first comprehensive legal framework on AI worldwide
- Adopted by the EU in 2024
- It applies to:
 - Providers of AI systems
 - Deployers (users) of AI systems
 - Importers and distributors
 - Even companies outside the EU if their AI affects people in the EU (extraterritorial effect, similar to GDPR)



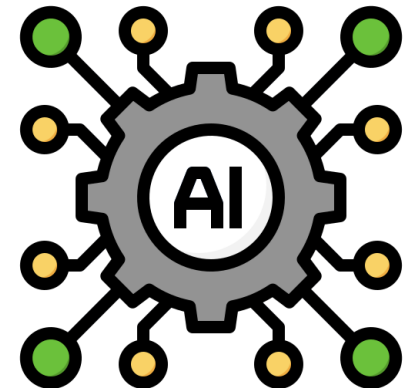
Definition of AI System

➤ AI System definition (simplified):

“An AI system is a machine-based system designed to operate with varying levels of autonomy that may generate outputs such as predictions, recommendations, or decisions influencing physical or virtual environments.”

➤ Examples:

- Machine learning models
- Deep learning systems
- Generative AI (e.g. OpenAI models)
- Biometric identification systems
- Risk scoring algorithms



Risk-Based Classification

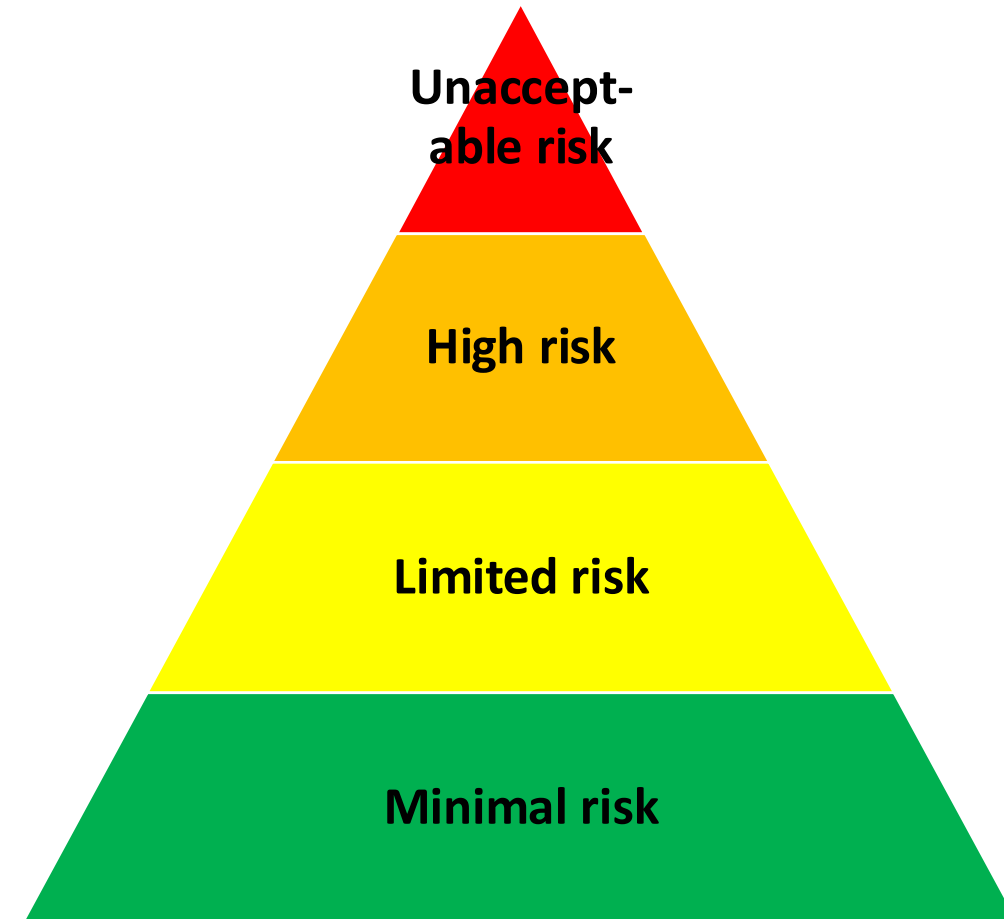
➤ The **AI-Act** classifies AI systems into four risk levels

Unacceptable risk → Prohibited systems

High risk → Permitted with strict requirements

Limited risk → Permitted with transparency obligations

Minimal risk → No obligations



Unacceptable Risk AI

- AI systems that are banned in the EU.
- Examples:
 - Social scoring systems (like those attributed to China)
 - AI manipulating vulnerable persons (children, disabled people)
 - Real-time remote biometric identification in public spaces (with narrow exceptions)
 - Emotion recognition in workplaces and schools (in many contexts)
- These systems are considered incompatible with EU fundamental rights.



High Risk AI

- High-risk areas include:
 - Biometric identification
 - Education (exam evaluation systems)
 - Employment and recruitment
 - Medical devices using AI
 - Law enforcement
 - Migration and border control
 - Administration of justice

- Most important things a providers must do:
 - Perform **risk assessment**
 - Ensure human **oversight**
 - Guarantee **accuracy, robustness** and **cybersecurity**
 - Maintain **documentation** and technical records



Limited Risk AI

- Examples:
 - Chatbots
 - Deepfake systems
 - AI content generators
- Main obligation: **Transparency**
- Users must be informed when:
 - They are interacting with AI
 - Content is artificially generated
- Example: If you interact with a chatbot like ChatGPT, you must know it is AI.



Minimal Risk AI

- Examples:
 - Spam filters
 - AI in video games
 - Recommendation systems for music/movies
- **No specific obligations** under AI Act.
- Most AI systems fall into this category.



GDPR and AI-Act

GDPR	AI-Act
Protects personal data	Regulates AI systems
Focuses on privacy	Focuses on safety and fundamental rights
Applies when personal data are processed	Applies regardless of personal data
Rights for data subjects	Obligations based on risk level
Supervised by national authorities	Supervised by EU AI Office (EU level)

- They are **complementary regulations** (e.g., an AI system that processes personal data must comply with BOTH GDPR and AI Act)

Limitation and Criticism

- Regulatory burden for innovation
- Uncertainty in definitions
- Risk classification complexity
- Enforcement challenges
- Global coordination issues
- On going debate: “Does regulations slow innovation or build trust?”



Open discussion

Should AI be regulated?

Who is responsible when AI causes harm?

Is transparency enough to protect people?

Would you trust AI in healthcare?